The *AI Agent Guardrails* Checklist

Fifteen yes/no checks a CTO or CISO can answer about their own AI agents today, without opening a repo. Run them in order. Answer "yes" only if you could show the evidence to an auditor this week. If you are unsure, the answer is "no". Tags name the NIST AI RMF function (Govern, Map, Measure, Manage) or the OWASP Top 10 for LLM Applications risk each check addresses.

1 ☐ YES ☐ NO — **INVENTORY** — NIST AI RMF, MAP

Do you have a written list of every AI agent and LLM feature in use, each with a named owner?

one list that includes vendor copilots, internal bots and shadow tools staff signed up for, plus the person accountable for each. A list that only covers what IT approved is a "no".

2 ☐ YES ☐ NO — **INVENTORY** — NIST AI RMF, MAP

Has each agent on that list been rated for how bad its worst failure would be?

a simple high, medium or low rating per agent, based on what it can touch (money, customer data, public output, production systems), agreed by the owner and someone from security.

3 ☐ YES ☐ NO — **DATA REACH** — OWASP LLM, SENSITIVE INFORMATION DISCLOSURE

Can you name every data source each agent can read, and is that limited to what its task needs?

a short per-agent list of systems, folders and databases it can reach. "It has the same access as the user who runs it" or "it can search the whole drive" is a "no".

4 ☐ YES ☐ NO — **TOOL PERMISSIONS** — OWASP LLM, EXCESSIVE AGENCY

Does each agent hold only the tools and permissions its task requires, with no shared admin account?

per-agent accounts or scoped keys, no agent running under an admin or service account shared with people, and no write or delete rights it does not use.

5 ☐ YES ☐ NO — **TOOL PERMISSIONS** — NIST AI RMF, MANAGE

Are agent credentials short-lived and can each agent reach only an approved list of outside sites?

keys that expire on their own rather than one long-lived key in a settings file, and outbound access blocked by default with named exceptions.

6 ☐ YES ☐ NO — **APPROVAL GATES** — OWASP LLM, EXCESSIVE AGENCY

Does a named human approve before any agent takes an action that is hard to undo?

a written list of gated actions (payments, deletions, sending email or messages outside the company, changing production settings) and proof the gate is enforced by the system, not by a line in the prompt.

7 ☐ YES ☐ NO — **APPROVAL GATES** — NIST AI RMF, MANAGE

If the approver does not respond in time, does the request default to "deny"?

a set response window per risk level, a backup reviewer, and a timeout that blocks the action rather than letting it through. The requester must never be able to approve their own request.

8 ☐ YES ☐ NO — **REFUSAL BEHAVIOUR** — OWASP LLM, PROMPT INJECTION

Does each agent refuse out-of-scope or rule-breaking requests, including instructions hidden inside documents, emails or web pages it reads?

a test in the last 90 days where someone planted an instruction in content the agent processes and the agent ignored it and gave a consistent refusal.

9 ☐ YES ☐ NO **REFUSAL BEHAVIOUR**

Is agent output checked before it reaches another system, a customer or a public channel?

a review step or automatic filter between the model's answer and the place it lands, so a wrong or harmful answer is caught before anyone acts on it.

OWASP LLM, IMPROPER OUTPUT HANDLING

10 ☐ YES ☐ NO **LOGGING**

Is every agent decision and every human override recorded with who, when and why, in a place the agent and its operators cannot edit?

you can pull the record for one decision from last month in under ten minutes, and overrides carry a named person and a written reason.

NIST AI RMF, MEASURE

11 ☐ YES ☐ NO **ROLLBACK**

Can you switch off any agent, or put it back to its last known good version, within one hour?

a named person with the authority to do it, a kill switch or version pin that does not need a code release, and a practice run in the last six months.

NIST AI RMF, MANAGE

12 ☐ YES ☐ NO **RED-TEAM**

Has someone tried to break each high-risk agent in the last 90 days, using test data rather than live customer data?

a dated record of attempts at jailbreaks, data extraction and misuse of its tools, what got through, and what was fixed. "The vendor tested it" is a "no".

NIST AI RMF, MEASURE

13 ☐ YES ☐ NO **PII**

Is personal data removed or masked before it reaches the model whenever the task does not need it?

names, ID numbers, account numbers and health details stripped or masked on the way in, and logs that record the decision without storing the personal data itself.

OWASP LLM, SENSITIVE INFORMATION DISCLOSURE

14 ☐ YES ☐ NO **VENDOR RETENTION**

Do you know, in writing, how long each model vendor keeps your prompts and outputs, and whether it trains on them?

the contract or data processing terms for each vendor, with retention period, training opt-out status and the region where data is stored. A marketing page is not enough.

OWASP LLM, SUPPLY CHAIN

15 ☐ YES ☐ NO **VENDOR RETENTION**

Have you set a retention period for your own prompts, outputs and agent logs that matches your legal obligations?

a written period per log type, signed off by legal or compliance, and automatic deletion when it ends.

NIST AI RMF, GOVERN

YOUR SCORE: COUNT YOUR "NO" ANSWERS

0 to 2 "no": Guarded. Your basics are in place. Recheck every quarter and after any new agent goes live.

3 to 6 "no": Gaps to close. Pick the "no" with the highest-risk agent behind it and fix it this month, starting with approval gates (6, 7) and rollback (11).

7 or more "no": Exposed. Your agents can act, read or leak more than you can see or stop. The AI Security Posture Audit maps every agent against the NIST AI RMF and the OWASP Top 10 for LLM Applications in 10 business days and hands you a ranked fix list. Book a fit call: https://cal.com/este-val/audit-fit-call

Sources

NIST AI Risk Management Framework: https://www.nist.gov/itl/ai-risk-management-framework
NIST AI 100-1, AI Risk Management Framework 1.0: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf
NIST AI 600-1, Generative AI Profile: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf
OWASP Top 10 for LLM Applications 2025: https://genai.owasp.org/llm-top-10/

EV **Esteban V.**

linkedin.com/in/valest
cal.com/este-val/audit-fit-call